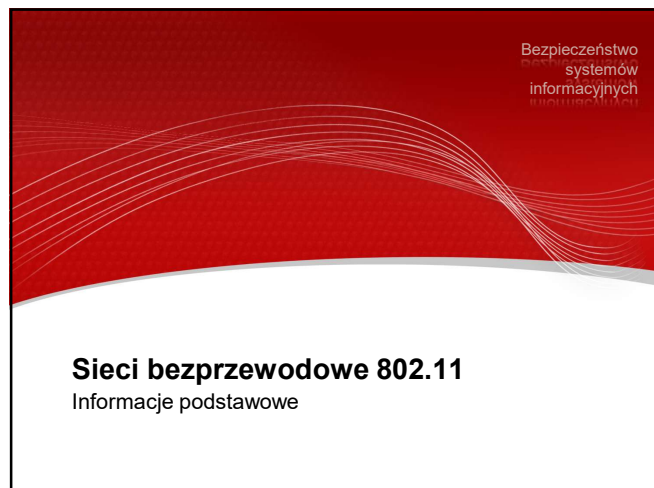
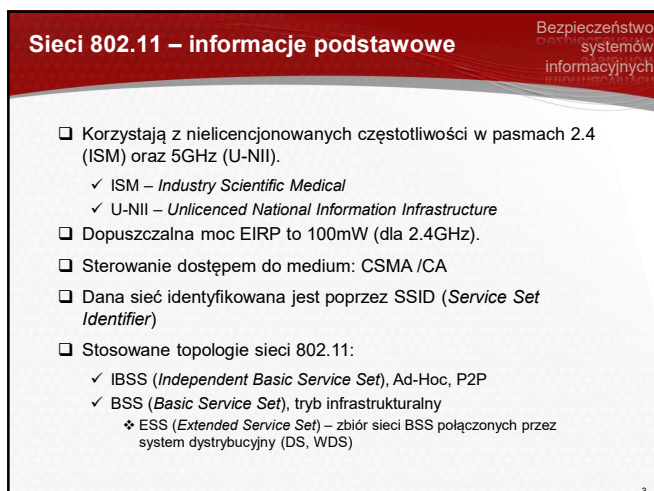




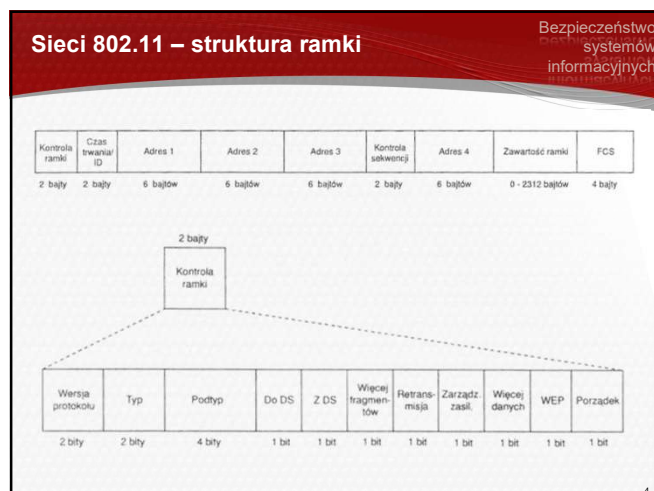
1



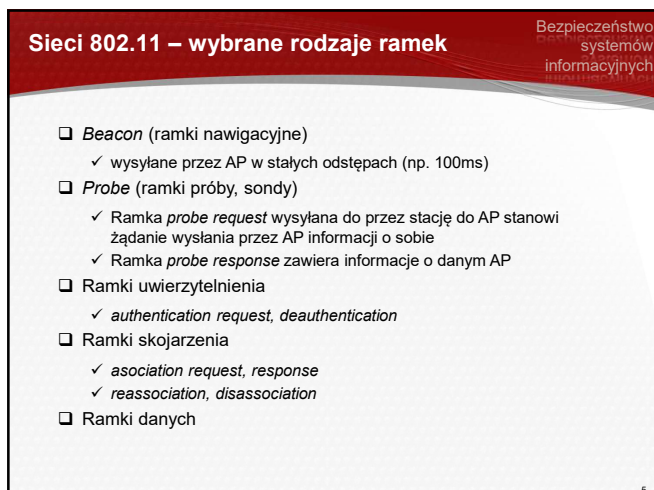
2



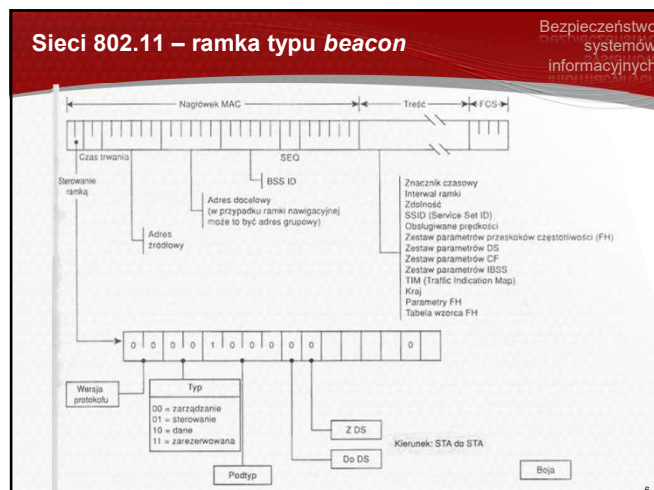
3



4



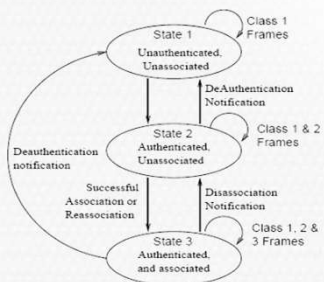
5



6

Sieci 802.11 – przyłączanie stacji

Bezpieczeństwo systemów informacyjnych



- ✓ Ramki klasy 1: beacon, probe, uwierzytelnianie, sygnalizacja
- ✓ Ramki klasy 2: kojarzenie stacji, anulowanie kojarzenia
- ✓ Ramki klasy 3: ramki danych

7

Sieci 802.11 – rodzaje uwierzytelniania

Bezpieczeństwo systemów informacyjnych

Uwierzytelnianie otwarte

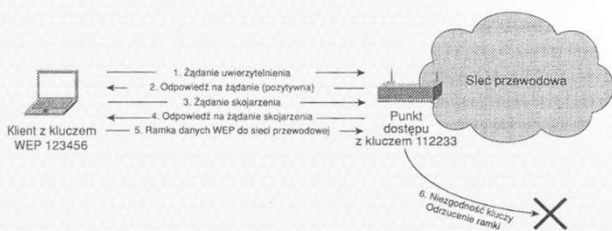
- ✓ Stosowane ze względów formalnych
- ✓ AP pozytywnie uwierzytelnia każde żądanie zawierające prawidłowy SSID
- ✓ Konkretny AP może uzależnić dopuszczenie danego klienta od spełnienia innych warunków (np. posiadania adresu MAC znajdującego się na liście w AP)
- ✓ Może (ale nie musi) być stosowane szyfrowanie WEP, wówczas ramki z niezgodnym kluczem WEP są odrzucane (wiele AP nie ma trybu otwartego z szyfrowaniem)

8

Sieci 802.11 – rodzaje uwierzytelniania

Bezpieczeństwo systemów informacyjnych

Uwierzytelnianie otwarte



9

Sieci 802.11 – rodzaje uwierzytelniania

Bezpieczeństwo systemów informacyjnych

Uwierzytelnianie ze współdzielonym kluczem

- ✓ Powiązane jest z protokołem szyfrowania WEP
- ✓ Uwierzytelniana jest stacja zawierająca prawidłowy SSID oraz zgodny z AP klucz WEP



10

Sieci 802.11 – rodzaje uwierzytelniania

Bezpieczeństwo systemów informacyjnych

Standard 802.11i (WPA2) całkowicie rozdziela procesy uwierzytelniania i szyfrowania

- ✓ Przy stosowaniu 802.11i z punktu widzenia standardu 802.11 jest to uwierzytelnienie otwarte

11

11

Sieci bezprzewodowe 802.11

Zagrożenia bezpieczeństwa

12

Sieci 802.11 - zagrożenia

Bezpieczeństwo systemów informacyjnych

- ❑ Sieci bezprzewodowe narażone są na znacznie większe zagrożenia niż inne ze względu na niekontrolowany fizycznie nośnik

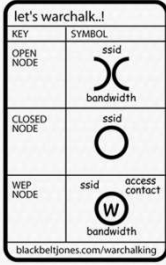



13

Sieci 802.11 - zagrożenia

Bezpieczeństwo systemów informacyjnych

- ❑ Ze względu na łatwość realizacji, próby uzyskiwania dostępu do sieci bezprzewodowych wykonywane są często dla zabawy i określane jako *wardriving* i *warchalking*




14

Sieci 802.11 - sniffing

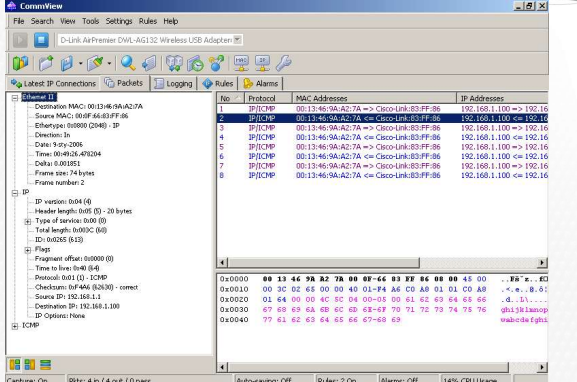
Bezpieczeństwo systemów informacyjnych

- ❑ Przy zastosowaniu odpowiednich anten kierunkowych o dużym zysku, sieci Wi-Fi mogą być podsłuchiwane nawet z odległości kilku kilometrów
- ❑ Realizacja *sniffingu* wymaga zestawu karta-driver umożliwiającego włączenie trybu monitorowania (*RF monitor mode*), będącego odpowiednikiem trybu *promiscuous mode* dla kart przewodowych
- ❑ Zazwyczaj „zwykłe” drivery nie mają takiej możliwości i dlatego programy analizatorów sieci Wi-Fi mają własne drivery dostosowane tylko do określonych chipsetów kart Wi-Fi (np. Atheros, Hermes, Prism 2.5)
 - ✓ Problem ten bardzo upraszcza się w systemach bazujących na Linuxie, gdzie można utworzyć wirtualny interfejs (np. *mon0*) skojarzony z określonym interfejsem fizycznym i mający domyślnie tryb monitora

15

Analizatory sieci WLAN - CommView

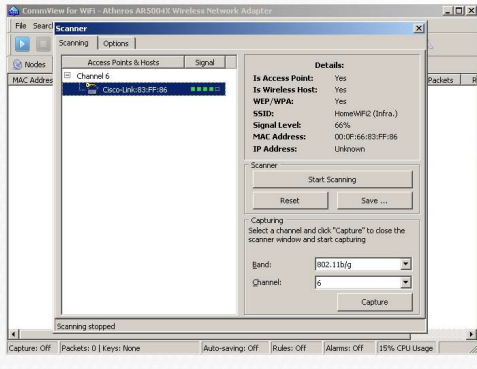
Bezpieczeństwo systemów informacyjnych



16

Analizator CommView for WiFi

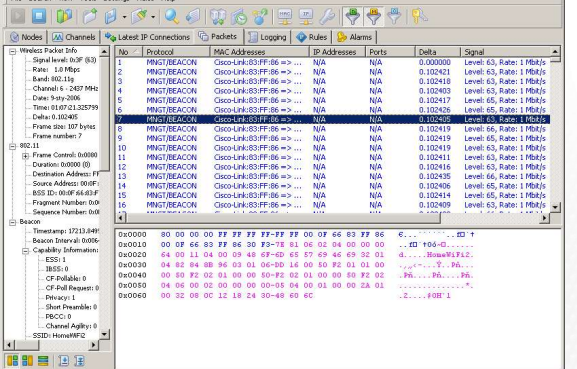
Bezpieczeństwo systemów informacyjnych



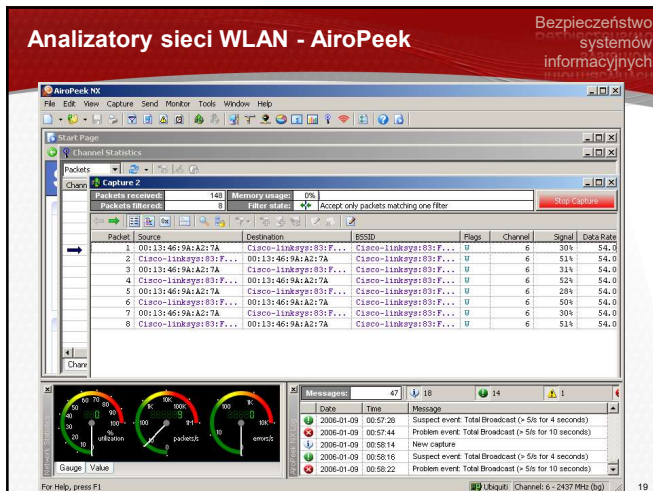
17

Analizator CommView for WiFi

Bezpieczeństwo systemów informacyjnych



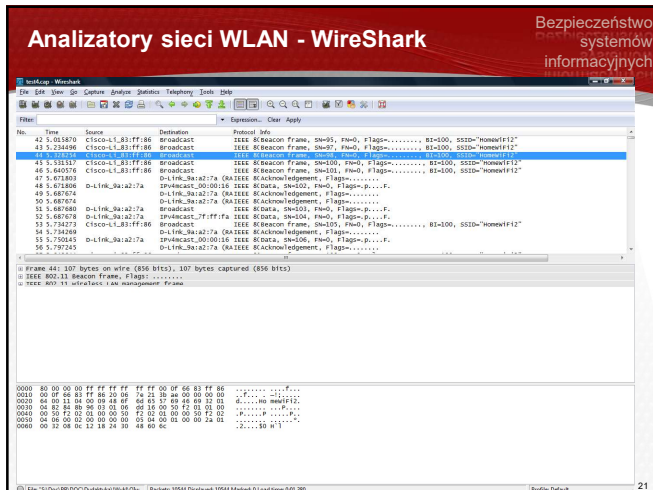
18



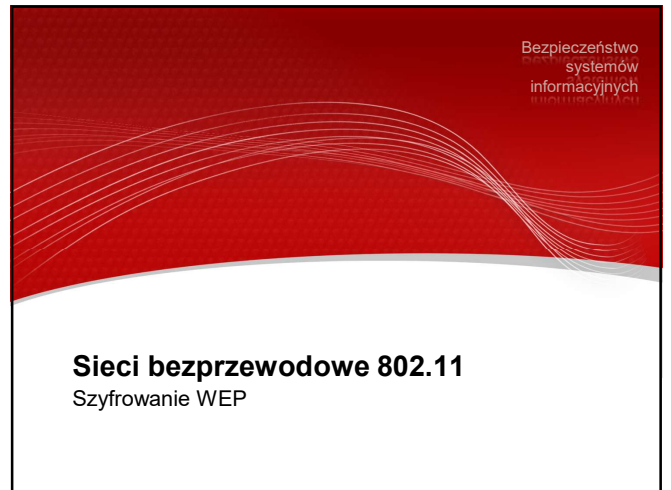
19



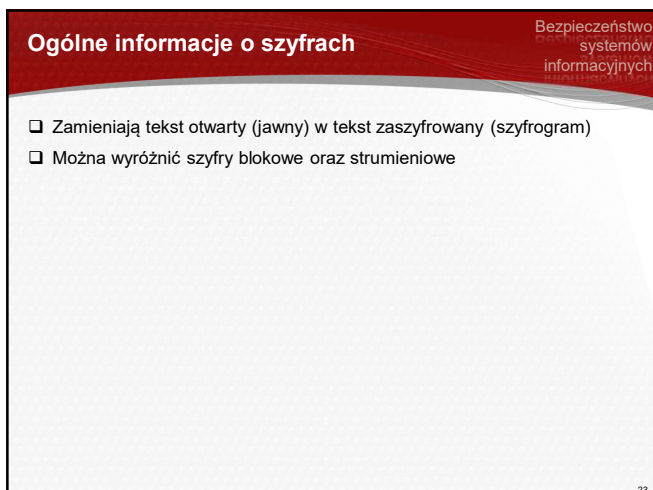
20



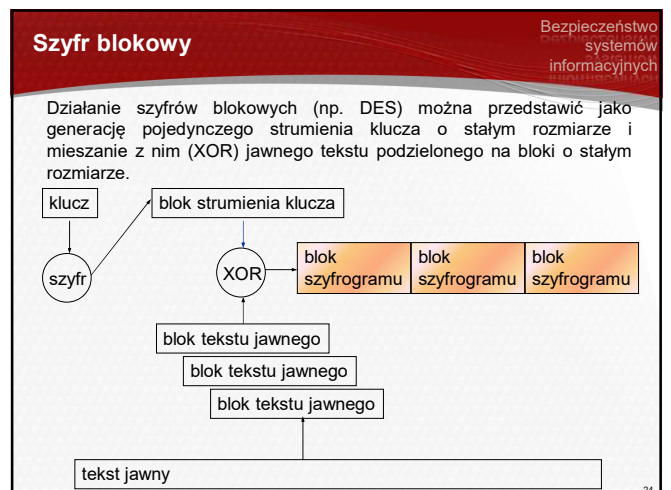
21



22



23



24

Szyfr strumieniowy

Bezpieczeństwo systemów informacyjnych

Działanie szyfrów strumieniowych (np. RC4) polega na bieżącej generacji kolejnych bitów strumienia klucza i mieszanie z nimi (XOR) kolejnych bitów tekstu jawnego.

25

Ogólne informacje o szyfrach

Bezpieczeństwo systemów informacyjnych

- Bezpośrednie szyfrowanie szyfrem strumieniowym lub blokowym określane jest jako tryb ECB (*Electronic Code Book*)
- W trybie ECB taki sam tekst jawny zawsze daje taki sam szyfrogram, co stanowi potencjalne zagrożenie dla bezpieczeństwa (można np. próbować wyróżniać stałe i zmienne wzorce w zaszyfrowanym tekście)

26

Ogólne informacje o szyfrach

Bezpieczeństwo systemów informacyjnych

- Problem trybu ECB można rozwiązać poprzez:
 - ✓ Tryby ze sprzężeniem zwrotnym (np. CBC, CFB); w zasadzie tylko dla szyfrów blokowych
 - ✓ Wektory inicjujące (IV) – są to liczby łączone z kluczem przed wygenerowaniem strumienia klucza. Zmiana IV powoduje zmianę strumienia klucza, a więc i zmianę szyfrogramu

27

Sieci 802.11 – szyfrowanie WEP

Bezpieczeństwo systemów informacyjnych

- Standard WEP (*Wire Equivalent Privacy*) został zawarty już w oryginalnym standardzie 802.11 opublikowanym w 1997r.
- Wykorzystuje szyfr strumieniowy RC4 (symetryczny) z predefiniowanymi po obu stronach statycznymi kluczami o długości 40 lub 104 bitów.
- Stosowane są 24-bitowe wektory inicjujące, co daje całkowitą długość klucza równą 64 lub 128 bitów.
- Wektory inicjujące przesyłane są w postaci jawnej i zmieniają w każdej transmitowanej ramce (ale nie jest to wymagane przez standard).
- Kontrola integralności danych realizowana jest poprzez sumę CRC32 (ICV – *Integrity Check Value*) wyznaczoną przed zaszyfrowaniem.

28

Sieci 802.11 – szyfrowanie WEP

Bezpieczeństwo systemów informacyjnych

Jawny			Zaszyfrowany	
Nagłówek MAC	IV	Zero zarezerw.	ID klucza	Dane
3 oktety	6 bitów	2 bity	2 bity	4 oktety
	000000			

29

Sieci 802.11 – deszyfrowanie WEP

Bezpieczeństwo systemów informacyjnych

30

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Sprawdzana jest tożsamość urządzeń, a nie użytkowników (utrata urządzenia z kluczami WEP stanowi zagrożenie dla sieci i wymusza zmianę kluczy na wszystkich urządzeniach w sieci)
- ❑ W przypadku generacji kluczy za pomocą słownej frazy (typowo 5 lub 13 znaków), 40 bitowy klucz ma efektywną długość tylko 21 bitów!
- ❑ Niezmienność klucza w czasie powoduje, że liczba możliwych strumieni klucza jest ograniczona do wartości pozwalającej na zgromadzenie wszystkich możliwych strumieni!
- ❑ Zamiast łamania klucza można więc zebrać wszystkie możliwe strumienie klucza

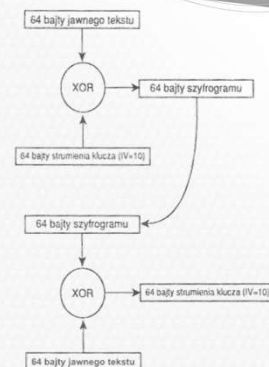
31

31

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Mając tekst jawny możliwe jest wyznaczenie strumienia klucza dla danego IV
- ❑ Ponieważ IV mogą się powtarzać, znany strumień klucza może być użyty do deszyfrowania przechwyconej transmisji lub do szyfrowania wstrzykiwanych ramek
- ❑ Wszystkich strumieni klucza może być tylko 2^{24}
- ❑ Dla pojedynczego strumienia o długości 1500 bajtów cały zbiór strumieni kluczy zajmuje 24GB



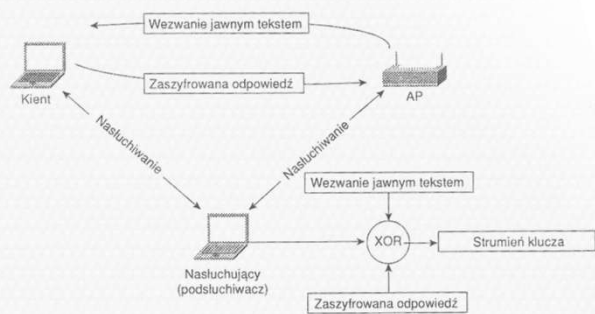
32

32

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Tekst jawny może być uzyskany z przechwyconego wezwania lub znanej odpowiedzi (np. na ping)



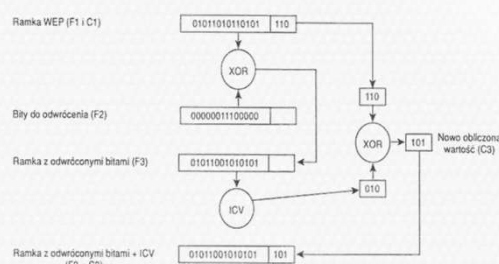
33

33

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Użycie CRC32 do testowania integralności komunikatu pozwala na zmianę dowolnych bitów w zaszyfrowanym tekście i wyznaczenie poprawnej sumy ICV!
- ❑ Wynika to z liniowości algorytmu CRC



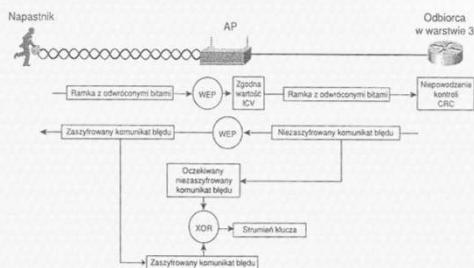
34

34

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Możliwość wyznaczenia poprawnego ICV dla zmienionego zaszyfrowanego komunikatu pozwala na znaczne przyspieszenie wyznaczenia strumieni kluczy (np. poprzez powodowanie generowania komunikatów o błędzie w otrzymanym pakiecie IP)



35

35

Szyfrowanie WEP – słabe strony

Bezpieczeństwo
systemów
informacyjnych

- ❑ Mając n bajtów strumienia klucza można uzyskać jego $n+1$ bajt wysyłając 256 wersji ramki wydłużonej o jeden bajt
- ❑ Uzyskana odpowiedź świadczy o poprawności dodanego bajtu
- ❑ W pewnych sytuacjach może to zmienić złożoność wyznaczenia strumienia klucza z 2^N na $256N$
- ❑ Jest to tzw. atak indukcyjny

36

36

Szyfrowanie WEP – słabe strony

- W 2001 roku analitycy kryptografii Scott Fluher, Itsik Mantin i Adi Shamir wykazali podatność RC4 na atak na niezmiennosc klucza oraz atak ze znanym IV
 - W skrócie wykorzystują one fakt, że dla niektórych wartości IV początkowe bajty strumienia klucza mogą być zależne jedynie od kilku bitów klucza
 - Atak metodą FMS wymaga zebrania około 4 milionów ramek
 - Atak FMS umożliwia wyznaczenie klucza, co pozwala na swobodne wejście atakującego do sieci bez operowania na dość dużym zbiorze (24GB) strumieni kluczy

37

37

Szyfrowanie WEP – słabe strony

- W 2004 roku pojawiły się ataki KoreKa oraz Arbaugha pozwalające wyznaczyć 40 bitowy klucz mając ok. 150 000 ramek z różnymi IV oraz 104 bitowy klucz mając ok. 500 000 ramek z różnymi wektorami IV
- Wykazano, że można wygenerować duży ruch w sieci poprzez wstrzykiwanie ramek (np. zapytań ARP), co znacznie skraca czas niezbędny do zebrania danych niezbędnych do ataku
- Do przeprowadzenia ataku może być wykorzystane narzędzie *AirCrack* oraz pomocnicze programy *Airodump* (do rejestracji ramek) oraz *Aireplay* (do wstrzykiwania ramek)

38

38

Airodump – rejestracja ramek

```

airodump 2.3 - (C) 2004,2005 Christophe Devine

usage: airodump <nic index> <nic type> <channel(s)> <output prefix> [ivs only flag]

Known network adapters:
23 3Com EtherLink XL 10/100 PCI dla pc[nej] karty PC Management NIC (3C995C-TX)
41 D-Link AirPremier DUL-BGL32 Wireless USB Adapter (rev.B)
43 Retheros R550040 Cardbus Wireless Network Adapter

Network interface index number -> 43
Interface types: 'a' = Realtek/Realtek
                  'a' = Aironet/Atheros
Network interface type (a/a) -> a
Channel(s): 1 to 14, 0 = all -> 6
(Note: if you specify the same output prefix, airodump will resume
the capture session by appending data to the existing capture file)
Output filename prefix -> test_64
(Note: to save space and only store the captured WEP IVs, press y.
The resulting capture file will only be useful for WEP cracking)
Only write WEP IVs (y/n) -> y
    
```

39

39

Airodump i Aircrack

```

Channel: 06 - airodump 2.3

BSSID      PUR  Beacons  # Data  CH  MB  ENC  ESSID
00:0F:66:83:FF:86  42  43847    156725  6  54  WEP  HomeWiFi2

BSSID      STATION    PUR  Packets  ESSID
00:0F:66:83:FF:86  00:13:46:9A:A2:70  30  317327  HomeWiFi2

C:\WINDOWS\system32\cmd.exe - aircrack -u 0 test_64.ivs

[00:34:07] Tested 118840 keys (got 156329 IVs)

KB  depth  bytes(bytes)
0  0/ 6  F6C 183 12C 153 37C 153 BB6 153 47C 123 F7C 123
1  0/ 1  50C 913 F8C 283 57C 223 B0C 183 68C 153 48C 133
2  0/ 1  56C 1293 F8C 683 85C 273 153 273 68C 283 82C 283
3  0/ 1  18C 1813 F8C 483 98C 253 45C 243 97C 273 28C 183
4  1/ 2  B0C 273 F1C 283 40C 183 B93 173 83C 153 79C 153
5  0/ 1  96C 853 F8C 293 B0C 253 C8C 253 F9C 223 19C 283
6  0/ 6  18C 283 F4C 283 47C 153 17C 153 B0C 153 C9C 153
7  0/ 4  B6C 163 23C 123 77C 183 F3C 183 87C 73 DEC 53
8  0/ 2  12C 153 87C 153 B9C 53 38C 53 84C 33 B8C 33
9  2/ 10 38C 383 2FC 383 84C 383 23C 373 85C 353 71C 333
10 0/ 1  C4C 223 68C 183 25C 183 98C 83 57C 53 85C 53
    
```

40

40

Aircrack – znalezione klucze

```

C:\WINDOWS\system32\cmd.exe - aircrack -u 0 -n 64 test_64.ivs

[00:00:01] Tested 2 keys (got 237571 IVs)

KB  depth  bytes(bytes)
0  0/ 5  12C 423 B8C 153 47C 123 B6C 183 77C 53
1  0/ 5  34C 713 B8C 283 57C 223 B0C 183 68C 153 48C 133
2  0/ 1  56C 1293 B8C 683 85C 273 153 273 68C 283 82C 283
3  0/ 8  78C 883 B8C 383 253 45C 243 97C 273 28C 183
4  0/ 1  98C 983 C0C 193 3FC 193 C8C 163 C9C 153 E4C 153

KEY FOUND! [ 12:34:56:78:90 ]

Press Ctrl-C to exit.

C:\WINDOWS\system32\cmd.exe - aircrack -u 0 -n 128 test_128.ivs

[00:03:43] Tested 897 keys (got 275408 IVs)

KB  depth  bytes(bytes)
0  0/ 1  12C 783 F7C 313 E7C 133 83C 123 18C 123 77C 123
1  0/ 1  24C 813 B8C 283 57C 223 B0C 183 68C 153 48C 133
2  0/ 1  56C 1913 B8C 683 85C 273 153 273 68C 283 82C 283
3  0/ 1  78C 3693 B8C 383 253 45C 243 97C 273 28C 183
4  1/ 5  98C 583 C8C 453 C8C 333 C9C 333 79C 283 C8C 283
5  1/ 9  12C 1283 B8C 883 283 57C 223 B0C 183 68C 153 48C 133
6  1/ 9  34C 283 57C 223 B0C 183 68C 153 48C 133
7  0/ 2  56C 853 B8C 683 85C 273 153 273 68C 283 82C 283
8  0/ 2  98C 383 F8C 283 57C 223 B0C 183 68C 153 48C 133
9  0/ 2  12C 1363 B8C 383 253 45C 243 97C 273 28C 183
10 0/ 2  24C 593 53C 543 23C 383 84C 383 23C 373 85C 353 71C 333
11 0/ 2  68C 373 B8C 273 E7C 253 F8C 183 11C 153 F7C 123

KEY FOUND! [ 12:34:56:78:90:12:34:56:78:90:12:34:56 ]

Press Ctrl-C to exit.
    
```

41

41

Sieci bezprzewodowe 802.11

Standard zabezpieczenia 802.11i

42

42

Standard 802.11i

Bezpieczeństwo systemów informacyjnych

- ❑ Jest to kompleksowy standard zabezpieczeń obejmujący uwierzytelnianie, integralność oraz poufność danych
- ❑ Został on opracowany przez IEEE i zatwierdzony w czerwcu 2004 przez Wi-Fi Alliance jako standard o komercyjnej nazwie WPA2 (Wi-Fi Protected Access)
- ❑ Wcześniej (2003) został określony tymczasowy standard WPA na podstawie szkicu 802.11i
- ❑ WPA/WPA2 umożliwia wzajemne uwierzytelnienie użytkowników i sieci za pomocą serwera AAA (w praktyce jest to 802.1x + RADIUS)
- ❑ Dla mniej wymagających zastosowań zdefiniowano też wersje WPA i WPA2 ze współdzielonym kluczem (*preshared key*), nie wymagające serwera AAA (oznaczane są one jako WPA-PSK lub WPA Personal)

43

Standard 802.11i

Bezpieczeństwo systemów informacyjnych

- ❑ 802.11i rozszerza oryginalny standard 802.11 o następujące elementy:
 - ✓ technikę *Robust Security Network* (RSN) pozwalającą na tworzenie bezpiecznych skojarzeń pomiędzy stacjami (RSNA – *Robust Security Network Association*) z wykorzystaniem dwóch nowych protokołów:
 - ❖ 4-Way Handshake
 - ❖ Group Key Handshake
 - ✓ protokoły zapewnienia poufności i integralności danych:
 - ❖ TKIP
 - ❖ CCMP

44

Standard 802.11i

Bezpieczeństwo systemów informacyjnych

- ❑ Sieci mogące tworzyć tylko połączenia RSNA określane są jako sieci RSN
 - ✓ Sieci które mogą tworzyć zarówno połączenia RSNA jak i pre-RSNA (WEP) określane są jako TSN (*Transition Security Network*)
 - ✓ Informacje o rodzajach obsługiwanych protokołów zabezpieczających rozgłaszane są w elemencie informacyjnym RSN IE z identyfikatorem 48 (elementy informacyjne stanowią pola przesłane w ramach zarządzania)
 - Ponadto stosowany jest też element informacyjny z identyfikatorem 0xDD interpretowany jako WPA (RSN IE jest traktowany jako WPA2)

Element ID	Length	Version	Group key cipher suite	Pairwise key cipher suite count	Pairwise key cipher suite list	Authentication and key management suite count	Authentication and key management suite list	RSN capabilities
Struktura RSN IE								

45

Standard 802.11i

Bezpieczeństwo systemów informacyjnych

WPA/WPA2 – tryb z serwerem uwierzytelniającym

46

Standard 802.11i

Bezpieczeństwo systemów informacyjnych

- ❑ Szyfrowanie WPA realizowane jest protokołem TKIP (*Temporal Key Integrity Protocol*) realizujący (w skrócie) szyfrowanie WEP z następującymi ulepszeniami:
 - ✓ zmieniający się klucz dla każdej kolejnej ramki
 - ✓ dodatkowy (w stosunku do ICV) kod zapewniający kontrolę integralności ramki (MIC - *Message Integrity Check*)
- ❑ WPA z protokołem TKIP zapewnia wysoki poziom zgodności z istniejącym sprzętem wykorzystującym WEP
- ❑ W standardzie WPA2 dodano szyfrowanie protokołem CCMP (*Counter-mode/CBC MAC Protocol*) korzystającym z algorytmu szyfrowania AES

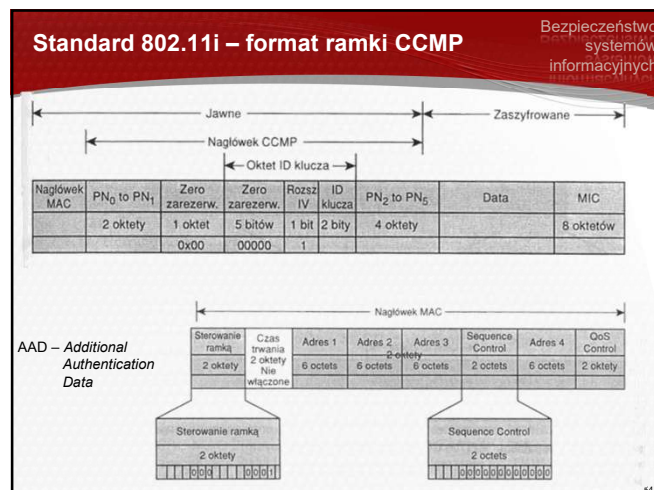
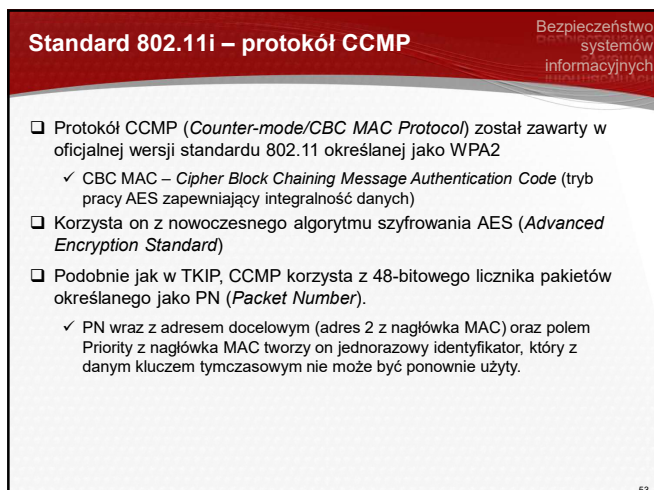
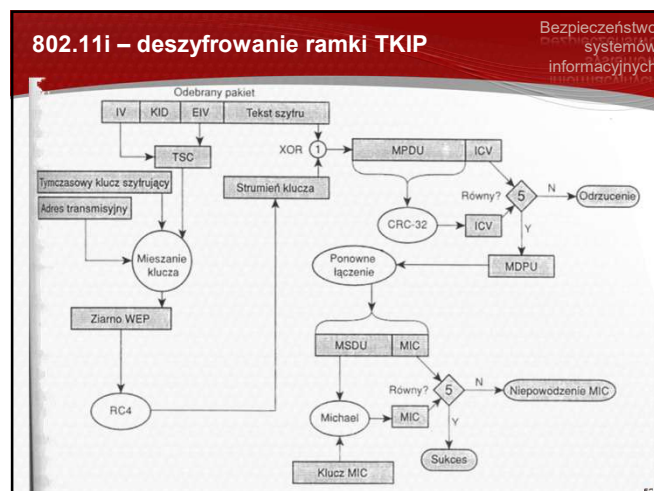
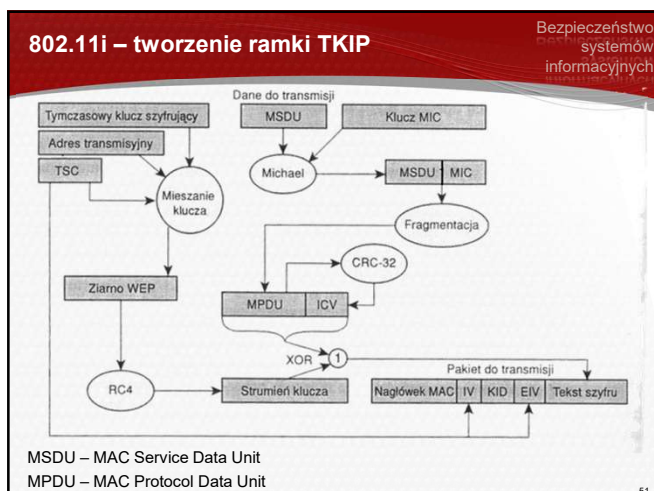
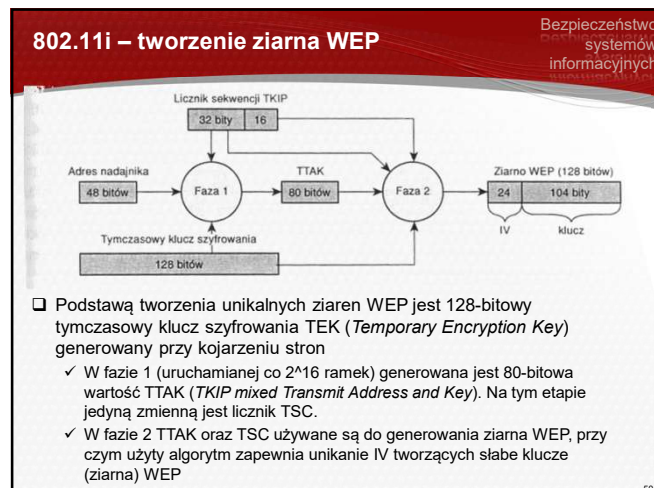
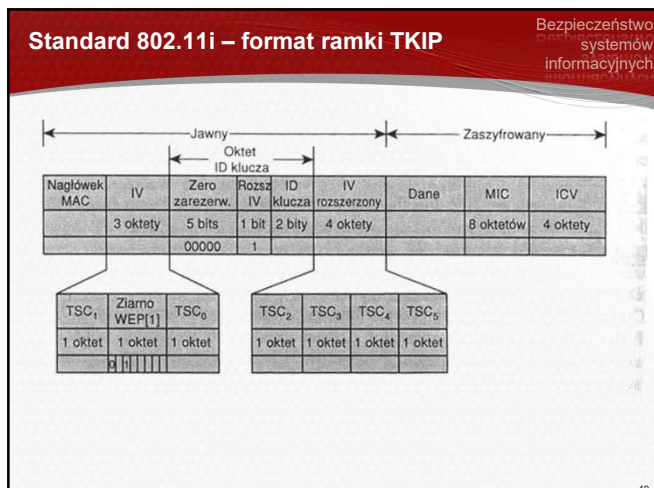
47

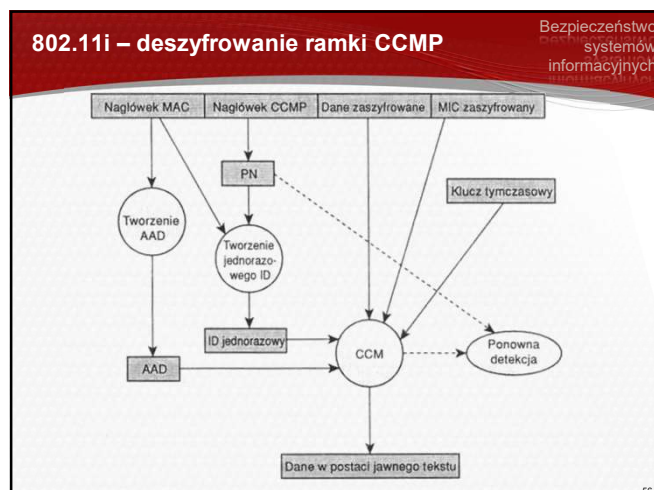
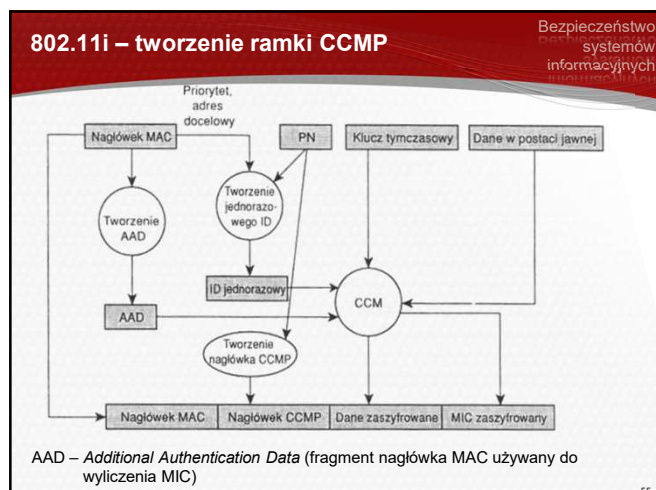
Standard 802.11i – protokół TKIP

Bezpieczeństwo systemów informacyjnych

- ❑ Protokół TKIP (*Temporal Key Integrity Protocol*) został opracowany jako tymczasowe rozwiązanie usuwające problemy związane z WEP przy zachowaniu zgodności z istniejącym sprzętem z zaimplementowanym WEP
- ❑ Zasadnicza zmiana polega na modyfikowaniu strumienia klucza WEP dla każdej ramki z zapobieganiem możliwości powtórnego wykorzystania danego strumienia klucza
 - W tym celu wprowadzono 48-bitowy licznik TSC (*TKIP Sequence Counter*) zwiększany o 1 przy każdej ramce. Odbiorcy śledzą najwyższe wartości TSC i odrzucają ramki z wartościami mniejszymi (ponieważ były one już użyte).
- ❑ Wprowadzono dodatkową kontrolę integralności danych poprzez generowanie kodu MIC (*Message Integrity Check*) z użyciem algorytmu mieszającego (haszującego) *Michael*
- ❑ Zachowany został główny mechanizm szyfrowania WEP z algorytmem RC4 ze 128-bitowym ziarnem (*seed*)

48





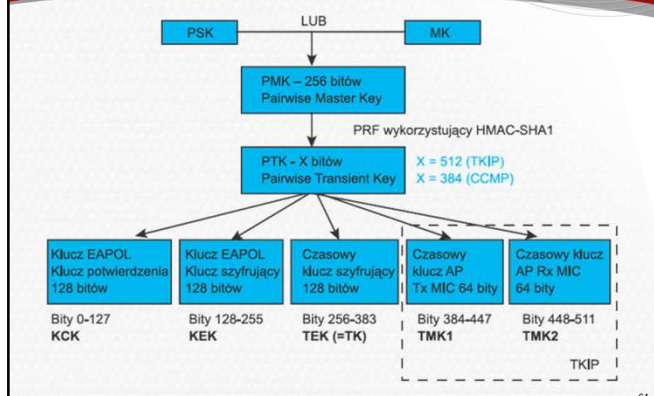
- ### 802.11i – zarządzanie kluczami
- Bezpieczeństwo systemów informacyjnych
- ❑ Standard 802.11i wprowadza schematy zarządzania kluczami, które pozwalają na separację procesu uwierzytelniania i dystrybucję kluczy
 - ❑ W odróżnieniu od WEP, 802.11i pozwala na indywidualizację kluczy dla poszczególnych użytkowników, dzięki czemu nie ma konieczności rekonfiguracji kluczy we wszystkich urządzeniach np. w przypadku utraty jakiegoś urządzenia przenośnego
 - ❑ Proces wymiany kluczy składa się z dwóch podstawowych faz:
 - ✓ ustanowienie klucza głównego
 - ✓ utworzenie i uzgodnienie pozostałych kluczy
 - ❑ W 802.11i stosowane są dwa typy kluczy
 - ✓ klucze pary (*pairwise*) dla ruchu indywidualnego (*unicast*)
 - ✓ klucze grupowe (*group*) dla ruchu rozgłoszeniowego
- 57

- ### 802.11i – klucz główny PMK
- Bezpieczeństwo systemów informacyjnych
- ❑ Klucz główny dla ruchu typu *unicast* oznaczany jest jako PMK (*Pairwise Master Key*) i może być ustanowiony na dwa sposoby:
 - ✓ W przypadku, gdy nie jest stosowane uwierzytelnianie 802.1x, klucz PMK generowany jest na podstawie hasła (8-64 znaków *passphrase*) wprowadzonego we wszystkich urządzeniach. Oprogramowanie niektórych urządzeń pozwala też na bezpośrednie wprowadzenie PMK w trybie hex (256 bitów).
 - ✓ Klucz PMK wyznaczony z hasła stanowi tzw. klucz prekonfigurowany PSK (*Pre-Shared Key*). Standard 802.11i stosujący klucz PSK określany jest jako WPA2-PSK lub WPA2 Personal i jest przeznaczony głównie do sieci domowych lub do małych firm.
 - ✓ Jeżeli stosowane jest uwierzytelnianie 802.1x, to PMK wyliczany jest z głównego klucza (MK) dla 802.1x
- 58

- ### 802.11i – klucz główny GMK
- Bezpieczeństwo systemów informacyjnych
- ❑ Klucz główny dla ruchu rozgłoszeniowego (GMK – *Group Master Key*) generowany jest przez AP i ze względów bezpieczeństwa może być odnawiany przy każdym anulowaniu skojarzenia stacji lub w regularnych odstępach czasu.
- 59

- ### 802.11i – hierarchia kluczy
- Bezpieczeństwo systemów informacyjnych
- ❑ Na podstawie PMK stacja i AP generują kolejne klucze, korzystając z funkcji pseudolosowej i tzw. negocjacji czteroetapowej.
 - ❑ Jako pierwszy generowany jest klucz tymczasowy PTK (*Pairwise Transient Key*). Dla TKIP ma on 512 bitów, a dla CCMP 384 bity.
 - ✓ $PTK = PRF-X(PMK, \text{„Pairwise key expansion”, Min}(AP_MAC, STA_MAC) || \text{Max}(AP_MAC, STA_MAC) || \text{Min}(ANonce, SNonce) || \text{Max}(ANonce, SNonce))$
 - ✓ PRF-X – Pseudo Random Function X=512 lub 384
 - ❑ Następnie PTK dzielony jest na trzy klucze:
 - ✓ EAPOL Key Confirmation Key (KCK – 128 bitów) używany do zapewnienia integralności komunikatów przy negocjacji czteroetapowej oraz negocjacji klucza grupowego
 - ✓ EAPOL Key Encryption Key (KEK – 128 bitów) używany do zapewnienia poufności przy negocjacji czteroetapowej oraz negocjacji klucza grupowego
 - ✓ Temporal Key (TK) używany do szyfrowania TKIP i CCMP
 - ❑ Podobnie generowane są klucze grupowe (PMK → GMK)
- 60

802.11i – klucze indywidualne



61

802.11i – negocjacja czteroetapowa

- ❑ AP generuje losową wartość jednorazową *ANonce* i wysyła ją do klienta (w sposób jawny)
 - ✓ Klient generuje własną wartość losową *SNonce* i na jej podstawie oraz otrzymanego *ANonce* generuje PTK i pozostałe klucze (korzysta przy tym z PMK, oraz adresów MAC AP i własnego)
- ❑ Klient odsyła do AP *SNonce* (w sposób jawny) oraz kod MIC tej wiadomości wyliczony przy użyciu wygenerowanego właśnie klucza KCK
 - ✓ Na podstawie otrzymanego *SNonce* AP wylicza PTK oraz pozostałe klucze i sprawdza otrzymany MIC korzystając z wyznaczonego właśnie klucza KCK

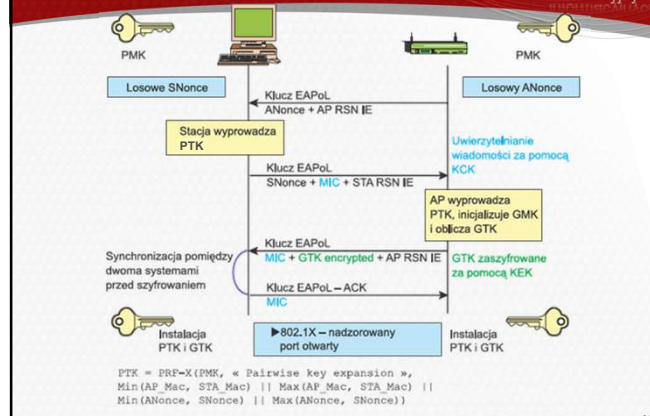
62

802.11i – negocjacja czteroetapowa c.d.

- ❑ AP wysła do klienta klucz GTK zaszyfrowany kluczem KEK (GTK wyznaczany jest z GMK oraz losowego G_{Nonce}) oraz MIC tej wiadomości wylczyony z użyciem KCK
 - ✓ Klient sprawdzi MIC otrzymany w trzecim komunikacie i w ten sposób upewnia się, że AP zna PMK oraz poprawnie wylczył PTK
- ❑ Klient sygnalizuje zakończenie negocjacji, instalację kluczy oraz rozpoczęcie używania KEK do szyfrowania
 - ✓ AP instaluje klucze i przechodzi do szyfrowania z użyciem KEK

63

802.11i – negocjacja czteroetapowa c.d.



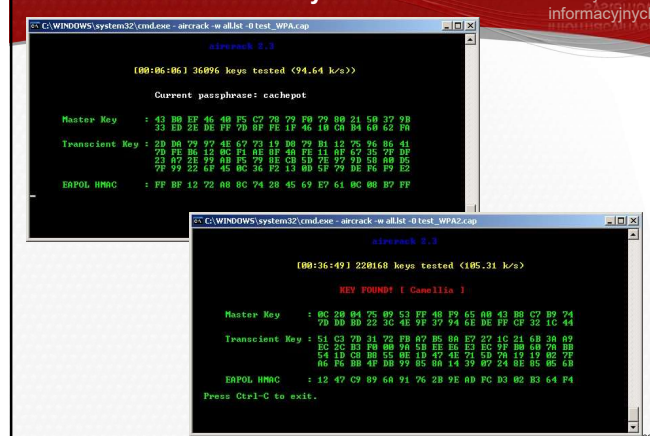
64

802.11i – słabe punkty

- ❑ W przypadku korzystania z PSK hasło może być poddane atakowi słownikowemu. Dlatego należy wybierać tzw. hasła niesłownikowe o długości co najmniej 20 znaków.
 - ✓ $PMK=PSK-PBKDF2$ (hasło, SSID, długość SSID, 4096, 256), gdzie PBKDF-2 jest funkcją zdefiniowaną w dokumencie PKCS#5, 4096 – liczba cykli mieszania, 256 – liczba bitów zwracanych przez funkcję)
 - ✓ Do przeprowadzenia ataku słownikowego potrzebne jest przechwycenie dwóch pierwszych komunikatów negocjacji czteroetapowej, co może być zrealizowane w sposób całkowicie pasywny
- ❑ Negocjacja czteroetapowa może być podatna na atak typu DoS
 - ✓ Pierwszy komunikat nie jest w żaden sposób uwierzytelniony i musi być składowany przez klienta do momentu otrzymania poprawnie podpisanego komunikatu trzeciego

65

802.11i – atak słownikowy na WPA-PSK



66

Komercyjna oferta łamania WPA-PSK

Bezpieczeństwo systemów informacyjnych



about run faq

An Introduction

WPA Cracker is a cloud cracking service for penetration testers and network auditors who need to check the security of WPA-PSK protected wireless networks.

WPA-PSK networks are vulnerable to dictionary attacks, but running a respectable-sized dictionary over a WPA network handshake can take days or weeks. WPA Cracker gives you access to a 400CPU cluster that will run your network capture against a 135 million word dictionary created specifically for WPA passwords. While this job would take over 5 days on a contemporary dual-core PC, on our cluster it takes an average of 20 minutes, for only \$17.

NEW: We now offer Germany dictionary support, a 294 million word extended English dictionary option, and ZIP file cracking.

Simply upload your network capture, start your job, and WPA Cracker will email you the results within minutes! [Run It](#) →

67

802.11i – atak KRACK

Bezpieczeństwo systemów informacyjnych

Październik 2017

<http://www.krackattacks.com>



Key Reinstallation Attacks
Breaking WPA2 by forcing nonce reuse

Discovered by [Mathy Vanhoef](#) of [imec-DistriNet](#), KU Leuven

INTRO DEMO DETAILS PAPER TOOLS Q&A

INTRODUCTION

We discovered serious weaknesses in WPA2, a protocol that secures all modern protected Wi-Fi networks. An attacker within range of a victim can exploit these weaknesses using key reinstallation attacks (KRACK). Concretely, attackers can use this novel attack technique to read information that was previously assumed to be safely encrypted. This can be abused to steal sensitive information such as credit card numbers, passwords, chat messages, email, photos, and so on. **The attack works against all modern protected Wi-Fi networks.** Depending on the network configuration, it is also possible to inject and manipulate data. For example, an attacker might be able to inject ransomware or other malware into websites.

The weaknesses are in the Wi-Fi standard itself, and not in individual products or implementations. Therefore, any correct implementation of WPA2 is likely affected. To prevent the attack, users must update affected products as soon as security updates become available. Note that if your device supports Wi-Fi, it is most likely affected. During our initial research, we discovered ourselves that Android, Linux, Apple, Windows, OpenBSD, MediaTek, Linksys, and others, are all affected by some variant of the attacks. For more information about specific products, consult the [database of CERT.CC](#), or contact your vendor.

The research behind the attack will be presented at the [Computer and Communications Security \(CCS\)](#) conference, and at the [Black Hat Europe](#) conference. Our [detailed research paper](#) can already be downloaded.

68

Bezpieczeństwo systemów informacyjnych

Bezpieczeństwo sieci Wi-Fi

Wi-Fi Protected Setup

69

Bezpieczeństwo systemów informacyjnych

WPS – Wi-Fi Protected Setup

- W 2007 roku Wi-Fi Alliance wprowadziło protokół WPS służący do automatycznej konfiguracji zabezpieczeń WPA2-PSK, przeznaczony dla użytkowników domowych



- Definiuje on następujące metody konfiguracji:
 - Push-Button-Connect (PBC) – użytkownik musi wykonać akcję naciśnięcia przycisku (może być on „wirtualny” zawarty w graficznym interfejsie oprogramowania) zarówno po stronie punktu dostępowego jak i po stronie interfejsu stacji klienckiej
 - Metoda z użyciem kodu PIN
 - Internal Registrar – użytkownik wprowadza PIN karty do ustawień punktu dostępowego
 - External Registrar – użytkownik wprowadza PIN punktu dostępowego w ustawieniach swojej karty sieciowej
 - Near-Field-Communication (NFC) – aby zarejestrować klienta musi być on zbliżony do punktu dostępowego (bazuje na „metce” RFID)

70

Bezpieczeństwo systemów informacyjnych

WPS – Wi-Fi Protected Setup

- W końcu grudnia 2011 roku Stefan Viehböck przedstawił metodę zdalnego uzyskania kodu PIN punktu dostępowego poprzez wykonanie znacznie mniejszej liczby prób niż przy przeszukiwaniu wszystkich możliwych wartości PIN
 - PIN ma 8 cyfr (z czego ostatnia jest sumą kontrolną), czyli 10 000 000 możliwych wartości
 - Punkt dostępowy osobno weryfikuje każdą połowę PINu i zwraca informację, czy jest ona poprawna
 - Sprawdzenie wszystkich możliwych wartości wymaga więc wykonania 11 000 prób, co w praktyce trwa ok. 10-15 godzin.
- Zaprezentowane programy znajdują PIN punktu dostępowego i na jego podstawie odczytują ustawione w nim hasło PSK

71

Bezpieczeństwo systemów informacyjnych

WPS – Wi-Fi Protected Setup

„Brakimdluwpw – KRACK attack”

December 27, 2011 <http://sviehb.wordpress.com/>

[Wi-Fi Protected Setup PIN brute force vulnerability](#)

Filed under: [advisories](#) — Stefan @ 3:00 am

A few weeks ago I decided to take a look at the [Wi-Fi Protected Setup](#) (WPS) technology. I noticed a few really bad design decisions which enable an efficient brute force attack, thus effectively breaking the security of pretty much all WPS-enabled Wi-Fi routers. As all of the more recent router models come with WPS enabled by default, this affects millions of devices worldwide.

I reported this vulnerability to [CERT.CC](#) and provided them with a list of (confirmed) affected vendors. CERT.CC has assigned [VU#723752](#) to this issue.

To my knowledge **none** of the vendors have reacted and released firmware with mitigations in place.

Detailed information about this vulnerability can be found in this paper: [Brute forcing Wi-Fi Protected Setup](#) – Please keep in mind that the devices mentioned there are just a tiny subset of the affected devices.

I would like to thank the guys at CERT for coordinating this vulnerability.

Update (12/29/2011 – 20:15 CET)

As you probably already know, this vulnerability was **independently** discovered by Craig Heffner ([dev:tvS0 Tactical Network Solutions](#)) as well – I was just the one who reported the vulnerability and released information about it first. Craig and his team have now released their tool “Reaver” over at [Google Code](#).

My PoC Brute Force Tool can be found [here](#). It’s a bit faster than Reaver, but will not work with all Wi-Fi adapters.

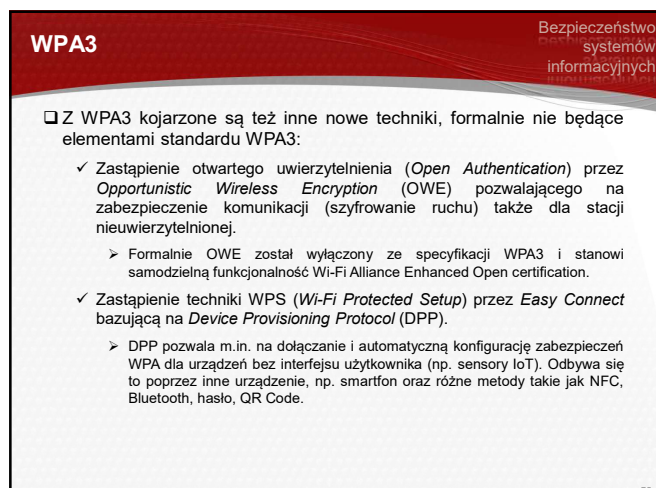
72



73



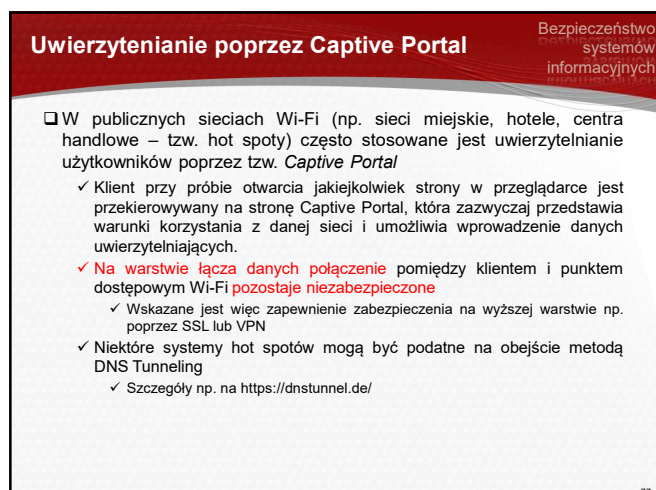
74



75



76



77



78

Podsumowanie

- ❑ Nie ma skutecznej metody obrony przed atakami typu DoS na sieci bezprzewodowe
 - ✓ W najprostszym wariancie może to być generator pokrywający całe pasmo, w bardziej wyrafinowanych urządzenia generujące ramki odłączające wybranych klientów od sieci
- ❑ Metoda WEP została całkowicie skompromitowana już w roku 2004 i nie powinna być używana
- ❑ W metodach WPA/WPA2-PSK obecnie najbardziej realnym zagrożeniem jest słownikowe łamanie hasła
 - ✓ Powinno się wybierać hasła o charakterze losowym i długości co najmniej 20 znaków
- ❑ Warto wyłączyć WPS w domowych routerach
 - ✓ Okazuje się, że mimo wyłączenia niektóre urządzenia zwracają odpowiedzi dotyczące zgodności odebranego PIN – warto sprawdzić czy do naszego urządzenia nie pojawił się upgrade oprogramowania

79

79

Literatura

- ❑ P. Roshan, J. Leary: „*Bezprzewodowe sieci LAN 802.11. Podstawy*”, MIKOM, Warszawa 2004
- ❑ K. Sankar, S. Sundaralingam, A. Balinsky, D. Miller: „*Bezpieczeństwo sieci bezprzewodowych*”, MIKOM, Warszawa 2005
- ❑ Czasopismo „*Hacking*” (np. 1/2006)



80

80